The Convergence of Identity & Security

Moving from Siloed Checklists to a Unified Common Operating Model

Presenter Name
Presenter Title

Identity is the Control Plane

Identity is central to modern breaches

Security investments ignore the reality of identity risk

We optimize for uptime, not control

The Identity Gap in Security

Modern environments stand on the shoulders of the tech debt that came before us

This gap continues to widen

New technology, new users, new risks, more attack paths

Security extends to where identities reach

The Identity Gap in Security

Wide, and widening every day

~60%

of organizations increased identity security spend... yet breaches continue.

The problem isn't just resources. It's also coordination.

Security and IT Operations are each doing their jobs, but the gap between them is exactly where attackers live.

Attackers live in the gaps between what 'should be' and what 'is.' Those gaps are often hidden in the complex web of identity relationships -- overlooked, misconfigured, and violating foundational security concepts.

Different Teams, Different Worlds

Security Team

Mandate: Enforce best practices, eliminate threats

Metric: Vulnerabilities closed, MTTD&R

Language: ESC1, pass-the-ticket, lateral movement

Reports to: CISO / Risk organization

Fear: Undetected breach, total compromise

IAM/IT Ops

Mandate: Keep services available, enable business

Metric: Uptime, ticket resolution time, user satisfaction

Language: Group Policy, service accounts, SLAs

Reports to: CIO / IT Director

Fear: Outage, productivity loss, business disruption

Success is Measured Differently

SECURITY MEASURES SUCCESS BY:

- Attack paths eliminated
- Time to detect (TTD) / Time to respond (TTR)
- Vulnerabilities remediated
- Pen test findings closed
- Attack surface reduced
- Compliance audit pass rate

OPERATIONS MEASURES SUCCESS BY:

- System / service uptime percentage
- Mean time to remediate (MTTR) for tickets
- User satisfaction / helpdesk call volume
- Provisioning speed (new users, new access)
- Change management success rate
- Zero production incidents per change

Neither set of metrics is wrong. They're just measuring entirely different things.

Transitive Control Problem

What IAM Sees:

User is a member of a standard AD group”

- Correct provisioning
- Least privilege at *face value*
- Access tied to job function

Transitive Control Problem

What Security sees:

"No alerts, no suspicious activity"

Endpoint behavior
Authentication anomalies
Known attack signatures

Transitive Control Problem

What both teams miss

That group membership can be **transitively privileged**.

Example:
User → Member of Helpdesk Group
Helpdesk Group → Can reset passwords for another group
That group → Has control over a service account
Service account → Has Domain Admin privileges

No single assignment looks dangerous, but the *path* leads to Domain Admin

Why does this happen?

IAM evaluates **direct access**

Security evaluates **events**

Neither evaluates **control paths across objects**

What should we be doing?

Identity team:

Map group permissions and delegation rights

Security team:

Map privilege escalation techniques (password reset, ACL abuse)

Together:

Model:
"Who can ultimately control Tier Zero?"

Prioritize:

Remove or constrain **delegation chains**, not just memberships

So, What Do We Agree On?

- ✓ Neither team wants to be the reason for a breach
- ✓ Downtime and outages are bad for everyone
- ✓ We are both understaffed and overloaded
- ✓ Attackers don't care about our org chart
- ✓ The environment changes faster than our policies do
- ✓ We need visibility to make good decisions

How do we get there?

Shift from Responsive to Proactive

Stop focusing only on events

Start managing identity structure

Adopt attacker perspective

Attack Path Management: The Bridge

Attack Path Management (APM) is the practice of continuously identifying, visualizing, prioritizing, and eliminating the routes adversaries use to reach critical assets, before they can be exploited.

IDENTIFY	PRIORITIZE	REMEDIATE	VALIDATE
Map all identity relationships -- direct and transitive -- across AD, Entra, Okta, GitHub, Jamf	Focus on choke points: single remediation steps that break hundreds of attack paths simultaneously	Practical, guided fixes that security and ops can implement together without breaking services	Confirm paths are closed. Track regressions. Measure real risk reduction over time.

For Security Teams

Quantifiable risk reduction. Clear attack path elimination metrics. Proactive rather than reactive posture.

For IT Ops / IAM Teams

Practical remediation guidance that doesn't break services. Shared visibility into why changes matter.

Practical Steps for Building a Common Operating Model

Get in the Same Room

- Joint kickoff: security + IT ops + IAM. Agree on what 'Tier Zero' means for your organization
- No blame. Frame as: 'we have blind spots we need to close together'
- Define what a critical asset is -- in business terms, not technical ones

Establish Shared Visibility

- Deploy APM tooling (e.g. BloodHound Enterprise) -- get continuous AD/Entra visibility
- First deliverable: a prioritized list of attack paths to your Tier Zero assets
- Share it with both teams. Let ops see what security sees. No more information silos.

Close the First Choke Points

- Pick the top 3 choke points. Assign joint ownership (security + the AD/IAM team)
- Use in-platform remediation guidance -- ops needs 'what exactly to change,' not 'fix the risk'
- Validate together. Celebrate together. Build the muscle memory.

Make It a Practice

- Integrate attack path findings into ticketing, change management, and risk register
- Monthly joint review: what paths closed, what regressed, what's new
- Board reporting: 'We eliminated X paths to Domain Admin this quarter, reducing exposure by Y%'

Integrate APM Into Existing Security Workflows

IDENTITY GOVERNANCE

Don't just look at who can log into what, understand the attack path exposure of identities

SIEM / SOAR

Add Attack path context to alerts, and coordinate sharper respo

PAM TOOLS

APM reveals incidental privilege PAM misses: nested groups, delegated rights, legacy accounts

ITDR

Attack path context enriches alerts -- prioritize by whether impacted identity has paths to critical assets

RISK, COMPLIANCE

Provide evidence of risk reduction to critical assets & identity risk and hygiene data for audit compliance

INCIDENT RESPONSE

APM shows which paths the attacker could use from the compromised identity

Find Metrics Both Teams Can Stand Behind

Stop measuring activity. Start measuring risk reduction

240

Attack Paths Eliminated

This Month

Concrete count of closed exposure routes. Security wins, ops can see what they fixed.

↓34%

Reduction

Paths to Tier Zero

Reduction in exposure to your most critical systems. Board-ready risk language

MTTR

Mean Time to Remediate

per finding

Operational metric ops understands. Shared accountability across teams.

18

high-impact fixes

Choke Points Resolved

Each choke point fix breaks many paths. Efficient use of ops team's time.

0

re-introduced

Attack Path Regressions

Did automation re-create what we just fixed? Tracks provisioning process health.

12

active / 0 new

Privilege Zone Violations

Compliance boundary status for regulated data. Audit-ready evidence.

Build a Culture of Collaboration

No Blame, Shared Ownership

When an attack path is found, it's not 'IT ops messed up.' It's 'we have a gap to close together.' The Jamf service account with self-escalation rights wasn't malicious -- it was a gap in collective awareness.

Translate, Don’t Condescend

Security teams: stop saying 'ESC1 misconfiguration' to an AD admin and saying 'any domain user can become Domain Admin using this certificate template' instead. Ops teams: stop saying 'that's too disruptive' without proposing an alternative.

Celebrate Joint Wins

When you close 240 attack paths to Domain Admin, that's a joint win for security AND for IT ops who did the remediation work. Track it, report it to leadership together, and build the shared identity around protecting the organization.

Build Identity Risk Awareness Across Teams

Every provisioning decision, every group membership, every service account created -- these are identity risk decisions. The goal is a culture where IT ops instinctively asks 'what attack path does this create?' before making a change.

Executing the Model

The technology exists. The methodologies are proven. The business case is clear. The differentiator will be execution.

Start with shared visibility -- both teams need to see the same attack path graph. You cannot coordinate around a problem nobody can see.

Establish joint ownership. Attack paths cross team boundaries. The remediation must too. Define who owns what before an incident forces the conversation.

Measure risk reduction together. Track paths eliminated, choke points closed, regressions caught. Report wins to leadership as a unified team.

Building a Common Operating Model Between Identity & Security Teams

SPECTEROPS

SO·CON

2026